



FUNDAMENTOS DE SEGURANÇA DA INFORMAÇÃO

Jeanine dos Santos
Barreto

Identificação e solução de problemas reais

Objetivos de aprendizagem

Ao final deste texto, você deve apresentar os seguintes aprendizados:

- Identificar problemas reais de segurança da informação.
- Reconhecer o fator humano como causa de ataques.
- Definir os procedimentos de testes de segurança da informação.

Introdução

Atualmente existe grande preocupação, por parte das organizações, com relação a problemas e incidentes causados por falhas na segurança da informação. Isso porque qualquer descuido pode gerar prejuízos, que podem ser enormes, ocasionando desde a perda de informações importantes até a perda financeira, de reputação e de imagem da empresa. Neste capítulo, você vai estudar a identificação e a solução de problemas reais de segurança da informação. Você também vai analisar o fator humano como causa de ataques, e vai explorar os procedimentos de testes de segurança da informação.

Os problemas de segurança da informação

A área de segurança da informação dispõe de ferramentas e técnicas que têm o propósito principal de preservar as organizações de quaisquer vulnerabilidades e ataques que possam se concretizar e fazer com que as informações organizacionais sejam modificadas, perdidas ou roubadas, trazendo prejuízos dos mais variados tipos para a organização e suas partes interessadas, como explicam Albuquerque e Ribeiro (2002).



Fique atento

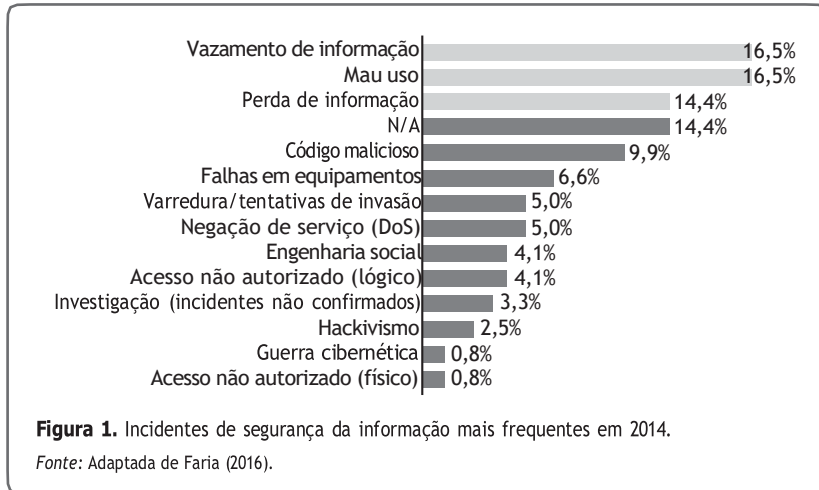
As partes interessadas de uma organização correspondem a todos os elementos que afetam ou são afetados pela organização, pelas suas atividades e pelas decisões tomadas por ela. Entre as partes interessadas estão os funcionários, os clientes, as empresas parceiras, os fornecedores, o governo, entre outras.

Apesar de todos os esforços empreendidos na segurança da informação das organizações, todo profissional que trabalha na área tem o entendimento de que é impossível eliminar totalmente as vulnerabilidades, as ameaças e as possibilidades de concretização dos ataques. É de conhecimento geral que a ocorrência de ataques bem-sucedidos a organizações vem crescendo e que, na maioria das vezes, eles acontecem por falhas na codificação ou outros tipos de vulnerabilidades nos sistemas e serviços e, principalmente, por falhas humanas. Isso se deve ao fato de que os sistemas são utilizados e desenvolvidos por pessoas, então, se a preocupação com a segurança da informação não for levada em consideração desde o momento da elaboração dos sistemas, a tendência é que as falhas abram portas para possíveis ataques bem-sucedidos. Uma vulnerabilidade, seja qual for o seu tamanho ou a sua origem, seja humana, tecnológica, financeira, ou de processos, possibilita que as falhas aconteçam e que, por consequência, indivíduos mal-intencionados consigam atacar as organizações e disponham das informações organizacionais da forma como desejarem. Vários são os tipos de prejuízos causados para a organização, que podem envolver desde a modificação, a perda ou o roubo de informações sigilosas, até prejuízos financeiros ou de imagem perante as suas partes interessadas.

São incontáveis os casos de ataques bem-sucedidos feitos diariamente contra organizações de todos os setores e portes. Esse tipo de fato transmite, para todas as partes envolvidas com uma organização, um sentimento de insegurança e descrédito, algo como se a empresa não se preocupasse com as informações que mantém em seu poder. Por causa dessas inúmeras tentativas de ataques é que existe a necessidade de se conhecer todos os pontos de vulnerabilidade e riscos existentes. O objetivo desse levantamento é mitigar o risco de ocorrerem invasões, roubo de informações e prejuízos para as empresas.

As alternativas para tratamento das vulnerabilidades que permitem as invasões às organizações tendem a ser padronizadas, uma vez que as causas

dos ataques giram em torno de causas humanas, como a engenharia social, as falhas na codificação de sistemas, as configurações indevidas de serviços e controles de acesso, entre outras. A Figura 1 mostra os incidentes de segurança da informação mais frequentes no ano de 2014, conforme Faria (2016).



Audiodescrição

A imagem é um gráfico de barras horizontais. As barras estão organizadas da parte superior para a inferior; as quatro primeiras estão em cinza-claro, e as demais, em cinza-escuro. À esquerda das barras, aparecem os rótulos dos incidentes. À direita das barras, aparecem os valores percentuais. Os itens são apresentados na seguinte ordem de leitura, de cima para baixo:

Vazamento de informação com 16,5%.

Mau uso com 16,5%.

Perda de informação com 14,4%.

N/A com 14,4%.

Código malicioso com 9,9%.

Falhas em equipamentos com 6,6%.

Varredura/tentativas de invasão com 5,0%.

Negação de serviço (DoS) com 5,0%.

Engenharia social com 4,1%.

Acesso não autorizado (lógico) com 4,1%.

Investigação (incidentes não confirmados) com 3,3%.

Hacktivismo com 2,5%.

Guerra cibernética com 0,8%.

Acesso não autorizado (físico) com 0,8%.

Figura 1. Incidentes de segurança da informação mais frequentes em 2014.

Fonte: Adaptada de Faria (2016).

Fim da audiodescrição

Os principais problemas reais de segurança da informação enfrentados atualmente pelas organizações são listados a seguir, conforme Faria (2016):

- **Ataques de vírus:** quando um ataque por vírus é bem-sucedido, pode danificar bancos de dados, trazer insatisfação por parte dos clientes, gerar prejuízos financeiros, retrabalho e muitos outros tipos de incômodos para as organizações.
- **Roubos de informações:** quando uma tentativa de roubo de informação se concretiza, podem ser roubadas informações sigilosas como números de cartões de crédito, de documentos, endereços, números de telefone, entre tantas outras. Existe uma preferência dos indivíduos maliciosos para invadir as pequenas e médias empresas, porque as grandes corporações normalmente possuem mais recursos para a segurança das suas informações. Existe também uma grande possibilidade de as informações sigilosas vazarem de dentro da empresa, com o auxílio de seus próprios colaboradores.
- **Indisponibilidade de serviços:** quando esse tipo de ataque acontece, os serviços disponibilizados on-line, ou constantemente, pela empresa, ficam indisponíveis para os usuários. Com isso, podem ficar indisponíveis serviços como comércio eletrônico, instituições financeiras e governamentais ou até mesmo servidores locais, quando não estiverem protegidos adequadamente. Dependendo do ataque, a credibilidade e a imagem da empresa são diretamente atingidas, principalmente se o caso vier a público antes que a organização tome conhecimento e consiga tomar alguma medida para sanar o problema.

Para evitar e solucionar os problemas ligados à segurança da informação, é interessante ter conhecimento de algumas das principais causas ligadas às falhas de segurança, ainda conforme Faria (2016):

- **Falta de sigilo:** envolve a exposição de informações sigilosas, muitas vezes pela utilização inadequada de criptografia. Isso demonstra desprezo da organização com relação à confidencialidade, o que pode prejudicar a imagem da empresa.
- **Falta de ferramentas de segurança atualizadas:** envolve a utilização

de antivírus e ferramentas de *firewall* desatualizadas, o que expõe a rede a todo tipo de ataques e ações maliciosas.

- **Falta de *backup* e plano de continuidade de negócio:** envolve o descuido com relação à guarda das informações e a falta de um plano de continuidade de negócio, que pode ser utilizado para que a recuperação dos dados seja rápida e eficiente e para que os processos de negócio não sejam interrompidos por muito tempo. Um plano de continuidade de negócio é fundamental para que todos saibam como agir em caso de incidentes de segurança e para que as operações da empresa sejam retomadas o mais rápido possível.
- **Falha de controle de acesso:** envolve a ausência de definição de perfis e níveis de acesso para cada usuário que acessa as informações da empresa. O controle de acesso deve ser estabelecido levando-se em conta a atividade e o cargo desempenhado pelos usuários.
- **Falta de restrição de dispositivos de armazenamento e acesso a *sites*:** envolve o fato de a empresa não impedir a utilização de *pendrives* e outros dispositivos, que permitam a cópia de informações e a instalação de aplicativos na rede da empresa, bem como o acesso a *sites* proibidos durante o horário de expediente, o que expõe a empresa a todo tipo de ataque de invasores.
- **Falta de política de segurança de informação:** envolve o desconhecimento de todos os colaboradores e demais envolvidos acerca da preocupação da organização com relação à segurança de suas informações. Sem uma política de segurança da informação, as pessoas não saberão como proceder em caso de incidente, nem mesmo a forma como devem agir em seu cotidiano para evitar a exposição das informações a possíveis ataques.

O fator humano nos ataques

Como vimos, a quantidade de tentativas de invasões e de ataques bem-sucedidos às informações privadas e de organizações vem crescendo muito nos últimos anos, principalmente pelo fato de que nunca antes um número tão expressivo de pessoas lidou com dispositivos de informática, tanto para seu divertimento quanto para atividades que envolvem finanças e dados sigilosos.

As pessoas representam o fator essencial para que a segurança da informação de uma organização seja bem-sucedida. A tecnologia existente para a proteção dos dados e das informações traz a possibilidade efetiva de diminuição de ameaças e vulnerabilidades, mas o que vai assegurar que se tire proveito do que a tecnologia proporciona são os usuários.

Existem alguns motivos, elencados por Fontes (2006), que explicam por que é tão importante considerar o fator humano na segurança da informação das organizações:

- as organizações são comandadas por pessoas, que vão definir qual será o nível de prioridade dado para a proteção das informações na organização;
- os sistemas informatizados são desenvolvidos por pessoas;
- os sistemas informatizados são operacionalizados por pessoas;
- os indivíduos mal-intencionados vão transformar as pessoas da organização em alvos, pois elas representam uma porta de entrada para supostos ataques;
- as políticas e regulamentos da organização são colocados em prática por pessoas, ou deixam de ser, caso não haja conscientização suficiente.

Os ataques se tornam bem-sucedidos à medida que a rede utilizada apresenta muitas vulnerabilidades e falhas, mas nem sempre se relacionam com a política de segurança da informação implementada pela empresa, dizendo respeito a atitudes humanas frente à utilização dos sistemas e dispositivos.

A prática de um invasor ou de um indivíduo mal-intencionado envolve encontrar falhas em computadores, em redes ou em sistemas, para que ele possa entrar no ambiente e dispor das informações da forma que melhor lhe convier. O fato é que essa atividade se torna muito mais fácil quando ele consegue enganar os usuários que estão por trás dos computadores e dos sistemas. É por conta disso que pode se observar nos últimos anos um aumento considerável

nos ataques, ou nas tentativas de ataques, que envolvem engenharia social. Por meio dela, o invasor convence o usuário a executar alguma ação que lhe vai possibilitar a entrada na rede, a infecção das máquinas com programas maliciosos e a exposição das informações guardadas.



Fique atento

A engenharia social consiste em um método de ataque à segurança da informação no qual o invasor se utiliza de persuasão, abusando da ingenuidade, da confiança e da falta de habilidade do usuário para obter informações que podem ser utilizadas para efetivar acessos não autorizados a informações ou a computadores.

Para manipular as pessoas, normalmente, o engenheiro social leva em consideração o fato de que as pessoas:

- tendem a acreditar nas outras com facilidade;
- tendem a querer ajudar as outras pessoas, mesmo que não as conheçam;
- são caridosas e generosas, em geral;
- tendem a se deixar manipular.

É provável que, durante um ataque que envolve características de engenharia social, o usuário nem fique sabendo que as suas ações causaram algum dano e permitiram o ataque, pois o criminoso explora a inocência e a ingenuidade da sua vítima, que entende estar agindo por bem, e nunca para causar algum mal à empresa ou a si própria.

A estratégia mais comum utilizada pelo engenheiro social é obter, antes do ataque, informações sobre a sua suposta vítima, como local de trabalho, idade, gostos, instituição bancária do qual é cliente, opções de lazer, entre outras. Partindo disso, o invasor encontra motivos para tentar um contato com o usuário escolhido, seja por telefone, e-mail, mensagem de texto, ou outro meio que a criatividade do invasor permitir.

No contato estabelecido, o invasor pode inventar para a sua vítima o recebimento de algum brinde, super descontos em lojas de seu interesse, a desatualização de algum programa utilizado no seu computador, a inclusão do seu nome no cadastro de devedores, apenas para citar alguns exemplos do que pode ser feito.

O usuário, interessado em alguma vantagem oferecida, ou com medo de que algo sério possa acontecer, quando o contato é feito por um órgão supostamente oficial, cede às instruções do invasor, expondo informações que, em outro contexto, não seriam divulgadas, ou ainda instalando programas em seu computador que, caso a vítima refletisse um pouco mais, não seriam instalados.

Por mais que os usuários saibam que os ataques maliciosos às informações estão cada vez mais comuns na atualidade e por mais que sejam cuidadosos na maior parte do tempo, eles são humanos. Por isso, muitas vezes são movidos pela emoção, pelo cansaço e pelo excesso de atividades do dia, ficando suscetíveis e expostos a ataques, conforme expõem Albuquerque e Ribeiro (2002). Por conta disso, a área de segurança da informação das organizações precisa, cada vez mais, de rigidez na sua estrutura, de um inventário das ameaças e vulnerabilidades envolvendo seus processos, sistemas e rede, de medidas capazes de identificar e-mails e *sites* falsos e, também, de uma definição concreta dos níveis e dos perfis de acesso às informações organizacionais sigilosas.

Entretanto, acima de todas essas necessidades, está talvez a principal, que é a de conscientizar os usuários acerca dos riscos e das ameaças de golpes e invasões, e dos prejuízos financeiros e de imagem que podem ser experimentados pela empresa, caso ocorra um ataque. É preciso elaborar campanhas educacionais sobre a utilização dos recursos tecnológicos disponíveis, fazendo com que os sistemas deixem de ser vistos como inimigos e passem a ser encarados como ferramentas que vão auxiliar nas atividades, desde que bem utilizadas.

Os testes de segurança da informação

Com o avanço do compartilhamento de informações por meio virtual, muitos são os motivos que levam as organizações a não estarem seguras. Entre eles pode-se citar as configurações de recursos mal definidas, os sistemas com falhas em códigos, as redes desprotegidas, a falta de atualização em aplicativos e a falta de treinamento e conscientização dos colaboradores, como afirmam Albuquerque e Ribeiro (2002).

Por outro lado, é muito comum também o excesso de confiança das empresas, que podem pensar que, pelo fato de as pessoas externas à sua organização não conhecerem detalhes de sua infraestrutura de rede, recursos e controles, ninguém terá interesse ou poderá invadi-la, levando a organização a imaginar que seu nível de risco tende a zero.

Nesse sentido, é muito importante que as organizações especifiquem com o máximo de rigor possível a sua estrutura de segurança da informação, criando sua política de segurança de informações, identificando todas as vulnerabilidades possíveis, definindo os controles e elaborando suas estratégias de defesa. Feito isso, é preciso elaborar formas de testes para colocar tudo isso em prática antes que um indivíduo mal-intencionado efetue uma tentativa

de invasão. É dessa forma que a organização vai estar segura de que a sua estratégia de segurança de informação é eficiente.

Esse tipo de teste vai servir para elencar vulnerabilidades e ameaças, por meio de simulações de ataques aos ativos da organização, seus sistemas, processos e equipamentos. É fundamental que os profissionais da área de segurança da informação participem dos testes, juntamente com representantes das diversas áreas e da gestão da empresa.



Fique atento

Ativo, no âmbito de uma organização, é qualquer coisa que tenha importância e valor para a empresa e que, por isso, precisa ser protegida de alguma maneira. Os ativos devem ser identificados, avaliados e ter regras para o tipo de uso a que se destinam, para que a organização possa manter um inventário deles.

Ao longo dos procedimentos de testes, é possível identificar e avaliar vulnerabilidades e falhas, analisando-as quanto aos atributos de disponibilidade, confidencialidade e autenticidade, que dizem respeito à segurança da informação.



Fique atento

Os principais atributos da segurança da informação, são:

- **disponibilidade**, que é a característica de um sistema de informação que mantém os seus serviços disponibilizados pelo máximo de tempo possível, resistindo a falhas de *hardware*, de *software* e também a falhas de energia;
- **confidencialidade**, que é a característica da informação que só é divulgada para aqueles indivíduos, processos e máquinas que têm autorização para acessá-la;
- **autenticidade**, que é a característica que diz que um indivíduo, um processo ou um computador é, realmente, quem ele “diz” ser.

Além desses atributos, ainda existe a **integridade**, que é a base das características da segurança da informação, pois é formada pela disponibilidade, confidencialidade e autenticidade.

Durante os testes de segurança da informação é preciso documentar todas as informações obtidas, elaborando um inventário de todos os resultados conseguidos. Cada atividade dos procedimentos de testes deve ser documentada com detalhes de dia, hora, atributos do remetente e do destinatário das mensagens, sejam eles internos ou externos, e ainda todas as técnicas, os métodos e as tecnologias empregadas nos testes.

São muitas as técnicas disponíveis para utilização durante os testes de segurança da informação, e a sua escolha deve levar em consideração as características da organização, para que possam ser simuladas todas as possibilidades de invasão por indivíduos maliciosos.

Por isso, antes de serem iniciados os procedimentos de testes, é necessário fazer o seu planejamento, que vai envolver a criação de um modelo ou do método para a execução dos testes. Nesse momento, serão verificados itens como os recursos humanos, os equipamentos, os tipos de ataques e as formas de atuação possíveis.

De acordo com Faria (2016), dentre os métodos possíveis para utilização nos procedimentos de testes de segurança da informação, estão:

- **sondagem e mapeamento:** consiste na varredura, por meio dos *hosts* ativos, ou nós da rede, para fazer a identificação das regras de *firewall* e dos serviços que estejam em execução no momento dos testes.
- **força bruta:** envolve a análise da política de senhas, dos serviços e dos controles de acesso e autenticação passíveis de ataques causados por ciclos de tentativa e erro envolvendo senhas.
- **avaliação de servidores:** envolve a identificação das vulnerabilidades nos servidores de internet, sujeitos à manipulação das requisições feitas na rede, visando a prejudicar a segurança dos serviços de internet da organização.
- **análise do tráfego:** envolve a análise do tráfego de rede, visando à identificação e à obtenção de informações sigilosas, como o *login*, a senha e os tipos e níveis de acesso dos usuários, por meio da manipulação do tráfego da rede.
- **injeção de código:** envolve a inclusão de códigos maliciosos nos sistemas para averiguar o comportamento das vulnerabilidades identificadas. A injeção de código tem como propósito principal identificar códigos de sistemas que apresentem vulnerabilidades quando os usuários informam algo e não existe tratamento adequado para a informação inserida. Dessa forma, o indivíduo mal-intencionado poderia inserir informações a serem tratadas pelo servidor, por meio de *cookies* ou outros tipos

de parâmetros, com o objetivo de provocar mau funcionamento no servidor da rede, expondo as informações e permitindo sua alteração, extravio ou roubo.

Os procedimentos de testes de invasão são essenciais e, por isso, é preciso que eles façam parte da política de segurança da informação da organização, sendo planejados e previstos como parte integrante do seu processo de implantação. Aliadas aos testes, as auditorias preventivas também têm grande importância, pois auxiliam na prevenção da exposição das informações.

Não existe uma maneira padronizada de fazer com que a segurança da informação, da rede e dos sistemas aconteça nas organizações, mas é importante que cada empresa encontre a sua maneira, levando em consideração suas características, seu ramo de atividade, seu porte, a quantidade de usuários que acessam suas informações e o nível de controle de acesso necessário.

Independentemente da maneira encontrada pela organização para fazer o gerenciamento da segurança das suas informações, do seu porte e do tipo de atividade com a qual trabalha, é importante que ela efetue os testes de segurança. Apesar de serem apenas uma das ferramentas utilizadas para colocar a política de segurança em prática, são eles os responsáveis por aproximar essa política da realidade, demonstrando os resultados que serão obtidos na prática.

Os procedimentos de testes visam a proteger a organização de qualquer tipo de ameaça e ataque que possa colocar em risco as informações organizacionais, sejam elas sigilosas ou públicas. É importante incluir os testes na política de segurança de informação, mesmo que os profissionais dessa área saibam que é impossível eliminar totalmente os riscos, pois as técnicas utilizadas pelos invasores tendem a ser mais adiantadas, quando comparadas aos meios de prevenção e controle. A execução de testes, mesmo não eliminando os riscos, tornará possível antever problemas reais e gerenciar as vulnerabilidades da empresa, demonstrando a preocupação com a segurança das suas informações.



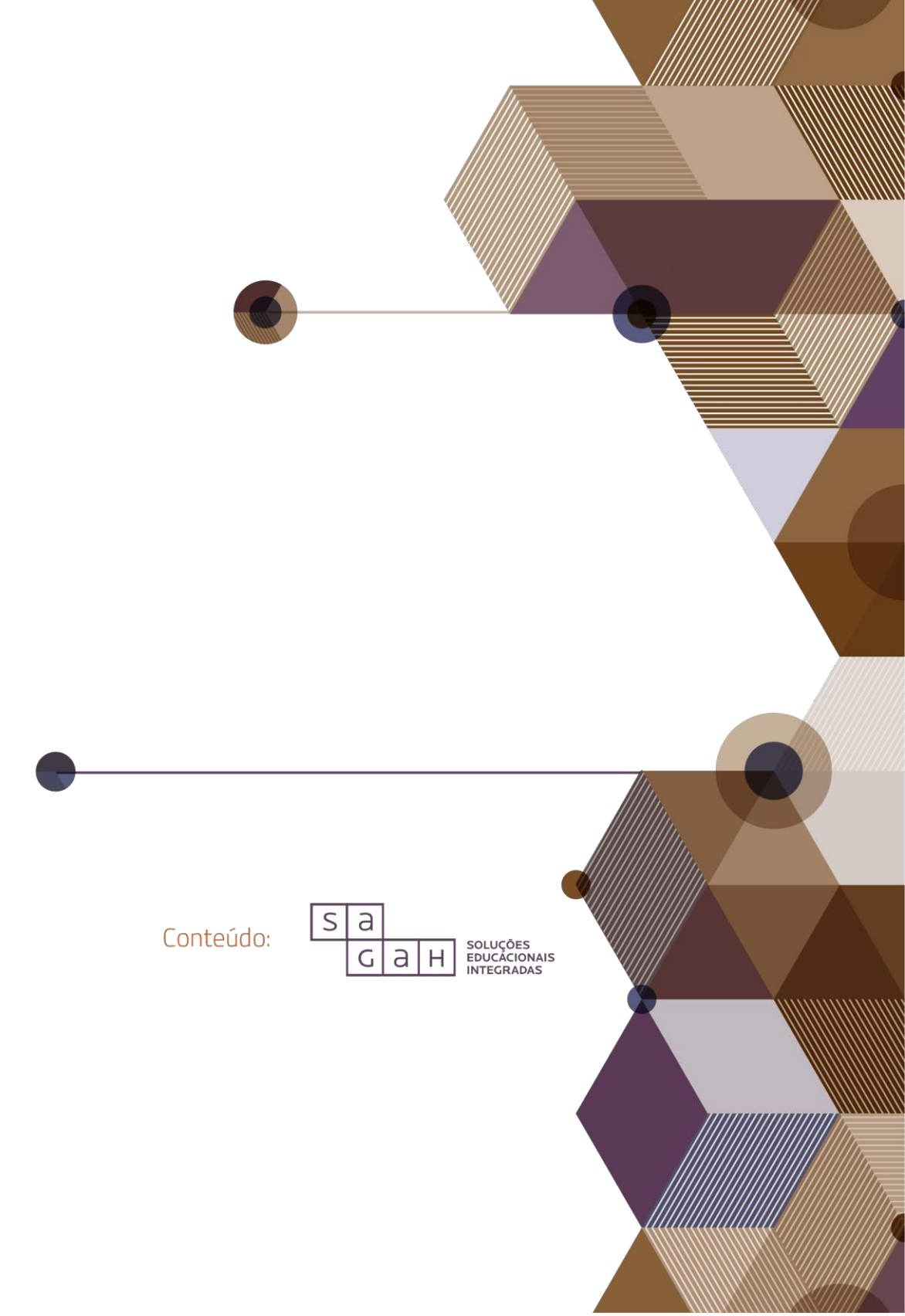
Referências

ALBUQUERQUE, R.; RIBEIRO, B. *Segurança no desenvolvimento de software*. Rio de Janeiro: Campus, 2002.

FARIA, R. G. L. *Fundamentos de segurança da informação*. Belo Horizonte: Ânima, 2016.

FONTES, E. *Segurança da informação: o usuário faz a diferença*. São Paulo: Saraiva, 2006.

Encerra aqui o trecho do livro disponibilizado para esta Unidade de Aprendizagem. Na Biblioteca Virtual da Instituição, você encontra a obra na íntegra.



Conteúdo:



SOLUÇÕES
EDUCACIONAIS
INTEGRADAS